

Consumer Authentication Controls & MFA Statement

Organization: otterfund (unincorporated; operating name) **Product:** otterfund (<https://otterfund.ai>) **Owner:** Ibrahim Al-Tawil (Software Engineer) **Date:** July 21, 2026

Why otterfund does not currently deploy consumer-facing MFA before Plaid Link

otterfund does not yet deploy application-level multi-factor authentication (MFA) for consumers before Plaid Link is surfaced. As an early-stage product, consumer MFA is on our near-term roadmap but has not yet been released. In the interim, the following authentication and security controls protect consumer accounts and, in particular, the bank-linking flow:

- **Managed, secure authentication.** User authentication is handled by **Supabase Auth** using industry-standard practices. Passwords are securely hashed and salted and are **never stored in plaintext**. Google OAuth sign-in is also offered.
- **Inherited MFA via Google OAuth.** Consumers who sign in with Google authenticate through Google's identity platform and **inherit any MFA / 2-Step Verification** enabled on their Google account.
- **Automated-abuse protection.** **Cloudflare Turnstile CAPTCHA** is enforced on authentication flows to mitigate credential-stuffing and automated attacks. Sensitive actions, including bank-connection requests, are **rate-limited and quota-enforced** per user.
- **Secure sessions and transport.** Sessions are managed by Supabase with server-side refresh. All traffic is encrypted with **TLS 1.2+ and HSTS is enforced**.
- **Bank authentication at the point of linking.** otterfund **never sees or stores users' bank credentials**. When a user links an account, they authenticate **directly with their financial institution through Plaid's secure Link flow**, which is gated by the bank's own authentication (frequently including the bank's own MFA). Plaid access tokens are **encrypted at rest (AES-256-GCM)**.

Roadmap

We plan to add consumer MFA — **TOTP authenticator apps, with passkey support to follow** — using Supabase Auth's native MFA capabilities, prioritized as the user base scales.

Residual risk

Given the controls above, and because the highest-risk action (bank linking) is protected by the financial institution's own authentication via Plaid, the residual risk from the absence of app-level MFA is limited

and will be further reduced when consumer MFA ships.